institution have the email address of the affected individuals.[566] In addition, 26 states allow for the notice to be made over the phone.[567] Of these 26 states, 7 provide that a condition for a telephonic notice is that contact is made directly with the affected individuals.[568]

All states allow, under some conditions, for substitute notification instead of the required methods of notification discussed above. The most common conditions include a specified large number of individuals to notify and/or a minimum dollar cost to notify the affected individuals. These conditions vary widely across states.[569] In most states, a substitute notice consists of all of the following elements: email notification to the affected individuals, a notice on the institution's website, and notification to major statewide media.[570] However, other states have fewer requirements.[571]

(3) Notification by Service Providers

Some data breach incidents involve service providers. Covered institutions may use service providers to perform certain business activities and functions, such as trading and order

---

566 *See* Ariz. Code § 18-552(F); Ind. Code 24-4.9-3-4.

567 *See. e.g.*, Conn. Stat. § 36a-701b.(e); N.Y. Gen. Bus. Law § 899-AA(5); 73 Pa. Stat. § 2302.

568 *See, e.g.*, Ariz. Code § 18-552(F); Mo. Stat. 407.1500 § 2(6); 9 Vt. Stat. Ann. § 2435(b)(6)(A).

569 For example, some states allow for a substitute notice if the number of affected individuals is above 1,000 or 5,000 or if the cost of providing notice is above $5,000 or $10,000, while many states have a threshold of 500,000 affected individuals or a cost threshold of $250,000. *See, e.g.*, Maine Rev. Stat. Tit. 10 § 1347(4); Miss. Code § 75-24-29(6); N.H. Rev. Stat. § 359-C:20(III); Cal. Civ. Code § 1798.82(j); Fla. Stat. § 501.171(4)(f); N.Y. Gen. Bus. Law § 899-AA(5).

570 *See, e.g.*, D.C. Code § 28-3851(2); La. Rev. Stat. § 51:3074(G); N.J. Stat. § 56:8-163(d).; Va. Code. Ann. § 18.2-186.6(A).

571 *See, e.g.*, Ala. Code § 8-38-5(e) ("Substitute notice shall include both of the following: 1. A conspicuous notice on the Internet website of the covered entity, if the covered entity maintains a website, for a period of 30 days. 2. Notice in print and in broadcast media, including major media in urban and rural areas where the affected individuals reside."); Fla. Stat. § 501.171(4)(f) ("Such substitute notice shall include the following: 1. A conspicuous notice on the Internet website of the covered entity if the covered entity maintains a website; and 2. Notice in print and to broadcast media, including major media in urban and rural areas where the affected individuals reside."); Tex. Bus. & Com. Code § 521.053(f) (requiring that under certain conditions, "the notice may be given by: (1) electronic mail, if the person has electronic mail addresses for the affected persons; (2) conspicuous posting of the notice on the person's website; or (3) notice published in or broadcast on major statewide media").

management, information technology functions, and cloud computing services. As a result of this outsourcing, service providers may receive, maintain, or process customer information, or be permitted to access it, and therefore a security incident at the service provider could expose information at or belonging to the covered institution. In general, state laws require persons and entities that maintain computerized data for other entities, but do not own or license that data, to notify the data-owning entity in the event of a data breach (so as to allow that entity to notify affected individuals).[572] However, several state laws provide that a covered institution may contract with the service provider such that the service provider directly notifies affected individuals of a data breach.[573] In addition, some states impose the responsibility of notifying affected individuals on entities that maintain or possess the data even if they do not own or license it.[574]

Some commenters opposed the proposed provision that would have required service providers to notify covered institutions of a breach of sensitive customer information within 48 hours.[575] A commenter further stated that our analysis of the effects of this requirement was

---

572 *See, e.g.*, Cal. Civ. Code § 1798.82(b); D.C. Code § 28-3852(b); N.Y. Gen. Bus. Law § 899-AA(3); Tex. Bus. & Com. Code § 521.053(c).

573 *See, e.g.*, Fla. Stat. § 501.171(6)(b); Ala. Code § 8-38-8. We do not have information on the frequency of such arrangements.

574 *See, e.g.*, Ky. Rev. Stat. 365.732(2) ("Any information holder shall disclose any breach of the security of the system, following discovery or notification of the breach in the security of the data, to any resident of Kentucky whose unencrypted personal information was, or is reasonably believed to have been, acquired by an unauthorized person."); Maine Rev. Stat. Tit. 10 § 1348(1)(B). ("If any other person who maintains computerized data that includes personal information becomes aware of a breach of the security of the system, the person shall conduct in good faith a reasonable and prompt investigation to determine the likelihood that personal information has been or will be misused and shall give notice of a breach of the security of the system following discovery or notification of the security breach to a resident of this State if misuse of the personal information has occurred or if it is reasonably possible that misuse will occur."). *See also* Thomas 2023, at § 2:21.

575 *See, e.g.*, ACLI Comment Letter.

incomplete.[576] We conducted supplemental analysis of the notification timeframe required by state laws for entities that do not own or license the compromised data to help analyze and respond to these comments, and to provide additional context for our analysis of the possible effects of the final amendments.[577]

In general, state laws provide a window for notification of the entity that owns or licenses the data by the entity that maintains the data.[578] Ten states provide a specific deadline of either 24 hours (one state),[579] 10 days (four states),[580] 45 days (four states),[581] or 60 days (one state).[582]

---

576 *See* Microsoft Comment Letter ("The cost-benefit analyses of the Proposed Rules do not identify why a 48-hour or shorter reporting period is optimal."). *See also supra* section II.A.4 for a discussion of the length of notification period.

577 *See infra* section IV.D.1.c.

578 A small number of states do not require such a notification. For example, Rhode Island does not distinguish between entities that own or license the data and those entities that do not, requiring all entities to notify customers directly (R.I. Gen. Laws § 11-49.3-4(a)(1) ("Any municipal agency, state agency, or person that stores, owns, collects, processes, maintains, acquires, uses, or licenses data that includes personal information shall provide notification as set forth in this section of any disclosure of personal information, or any breach of the security of the system, that poses a significant risk of identity theft to any resident of Rhode Island whose personal information was, or is reasonably believed to have been, acquired by an unauthorized person or entity."). Similarly, South Dakota does not have a provision for persons or businesses that do not own or license computerized personal data (SDCL §§ 22-40-19 through 22-40-26).

579 *See* Ga. Code § 10-1-912(b) ("Any person or business that maintains computerized data on behalf of an information broker or data collector that includes personal information of individuals that the person or business does not own shall notify the information broker or data collector of any breach of the security of the system within 24 hours following discovery, if the personal information was, or is reasonably believed to have been, acquired by an unauthorized person.").

580 *See, e.g.*, Md. Comm. Code § 14-3504(c) ("Except as provided in subsection (d) of this section, the notification required under paragraph (1) of this subsection shall be given as soon as reasonably practicable, but not later than 10 days after the business discovers or is notified of the breach of the security of a system.").

581 *See, e.g.*, Tenn. Code Ann. § 47-18-2107(c) ("Any information holder that maintains computerized data that includes personal information that the information holder does not own shall notify the owner or licensee of the information of any breach of system security if the personal information was, or is reasonably believed to have been, acquired by an unauthorized person. The disclosure must be made no later than forty-five (45) days from the discovery or notification of the breach of system security, unless a longer period of time is required due to the legitimate needs of law enforcement, as provided in subsection (d).").

582 *See* La. Rev. Stat. § 51:3074(E) ("The notification required pursuant to Subsections C and D of this Section shall be made in the most expedient time possible and without unreasonable delay but not later than sixty days from the discovery of the breach, consistent with the legitimate needs of law enforcement, as provided in Subsection F of this Section, or any measures necessary to determine the scope of the breach, prevent further disclosures, and restore the reasonable integrity of the data system.").

Thirty-eight states provide instead a general principle such as "as soon as practicable" or "without unreasonable delay."[583] In particular, 24 states require the notification to take place immediately after the discovery of the breach or the determination that a breach has occurred.[584] Figure 5 plots the frequency of these different provisions across state laws. This variation across state laws in timelines for (1) notification of the entity that owns or licenses the data by the entity that maintains the data and (2) notification of the affected individuals by the entity that owns or licenses the data can result in widely different lengths of time between the discovery of a breach and the time the affected individuals are notified. In addition, variations in these state laws could result in residents of one state receiving notice while residents of another receive no notice for the same data breach incident.[585]

---

583 *See, e.g.*, Miss. Code § 75-24-29(4) ("Any person who conducts business in this state that maintains computerized data which includes personal information that the person does not own or license shall notify the owner or licensee of the information of any breach of the security of the data as soon as practicable following its discovery, if the personal information was, or is reasonably believed to have been, acquired by an unauthorized person for fraudulent purposes."); Va. Code. Ann. § 18.2-186.6(D) ("An individual or entity that maintains computerized data that includes personal information that the individual or entity does not own or license shall notify the owner or licensee of the information of any breach of the security of the system without unreasonable delay following discovery of the breach of the security of the system").

584 *See, e.g.*, Ark. Code § 4-110-105(b), N.C. Stat. § 75-65(b), and Utah Code 13-44-202(3). For many of these states, this immediate notification can be delayed if the delay is requested by a law enforcement agency.

585 *See supra* footnote 578 on South Dakota. In addition, in some states, notification from the service provider to the information owner is required only in the case of fraud or misuse. *See, e.g.*, Miss. Code § 75-24-29(4) (requiring notification if the information was or is reasonably believed to have been acquired by an unauthorized person for fraudulent purposes); Colo. Rev. Stat. § 6-1-716(2)(b) (requiring notification if misuse of personal information about a Colorado resident occurred or is likely to occur).

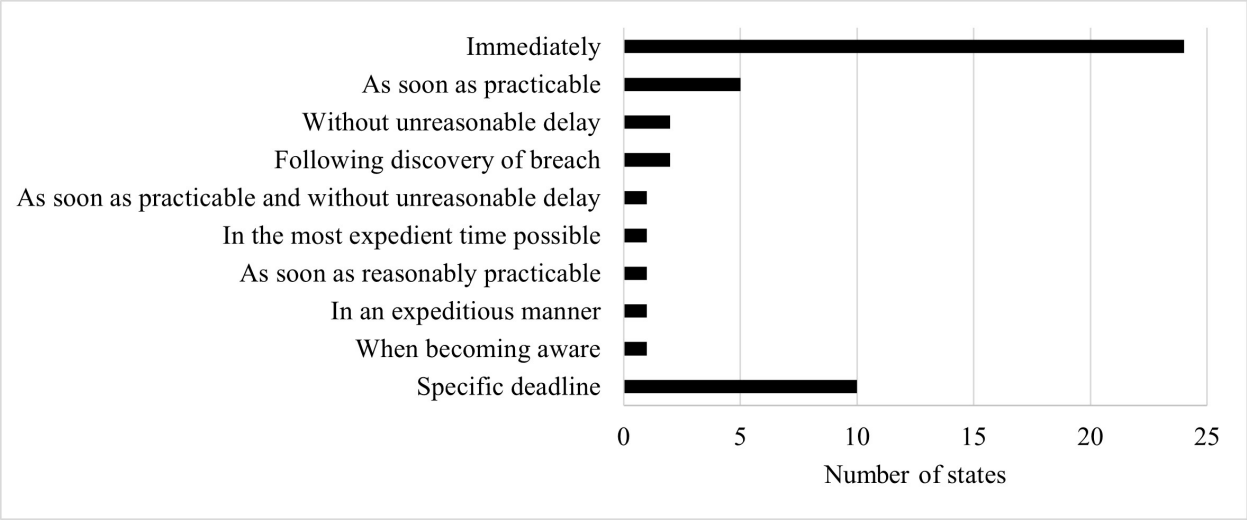

Figure 5: Frequency of timeline requirements for notification of entities that own or license data by entities that maintain but do not own or license data in case of breach in state laws. Data source: State law in 2023.

Some of the service providers that will be affected by the final amendments are covered institutions themselves.[586] Also, some entities that are covered institutions but not service providers under the final amendments could, under state law, be entities that maintain but do not own or license that data, meaning they may have an obligation under state law to notify the data owner.[587] In particular, commenters stated that transfer agents were generally considered service providers of the securities issuers under state laws.[588] State laws typically require transfer agents to notify the securities issuers in case of security breach, which in turn must notify the affected customers. One commenter stated that transfer agents were, in addition, often required by contract to notify their securities issuer clients in case of data breach.[589] Another commenter

586 *See supra* section II.A.3.a.

587 This could be the case, for example, of transfer agents providing services only to publicly traded companies that are not covered institutions.

588 *See, e.g.*, Computershare Comment Letter ("It is also contrary to privacy laws that deem the issuer to be the 'controller' or 'business' with respect to securityholders and their data and deem the transfer agent based on its role to be the 'processor' or 'service provider.'").

589 *See* STA Comment Letter 2.

stated that it was not uncommon for covered institutions to require, by contract or agreement, that their service providers, including transfer agents, notify them in case of security breach.[590] Hence, we expect that all or almost all covered institutions and their service providers are already complying with one or more notification requirements, pursuant to either state law or contract.[591]

b. Customer Information Safeguards

Regulation S-P, prior to the adoption of the amendments, required all covered institutions to adopt written policies and procedures reasonably designed to: "(i) insure [sic] the security and confidentiality of customer records and information; (ii) protect against any anticipated threats or hazards to the security or integrity of customer records and information; and (iii) protect against unauthorized access to or use of customer records and information that could result in substantial harm or inconvenience to any customer."[592] In addition, Regulation S-P established limitations on how covered institutions may disclose nonpublic personal information about a consumer to nonaffiliated third parties.[593] It also established limitations on the further disclosure of nonpublic personal information received by a covered institution from a nonaffiliated financial institution, as well as limitations on the further disclosure of nonpublic personal information disclosed from a covered institution to a nonaffiliated third party.[594] Before this adoption, Regulation S-P did not

---

590 *See* ICI Comment Letter 1.

591 Even if a state does not have specific requirements for entities that do not own or license computerized personal or protected information (such as South Dakota, *see supra* footnote 578), it is unlikely, by the nature of the transfer agent business, that a transfer agent would have access to customer information of individuals residing in this state only.

592 17 CFR 248.30. *See also* Compliance Programs of Investment Companies and Investment Advisers, Investment Advisers Act Release No. 2204 (Dec. 17, 2003) [68 FR 74714 (Dec. 24, 2003)], at n.22 ("Compliance Program Release") (stating expectation that policies and procedures would address safeguards for the privacy protection of client records and information and noting the applicability of Regulation S-P); *see also supra* section II.B.2 explaining that prior to these final amendments, the safeguards rule did not apply to any transfer agents, and the disposal rule applied only to transfer agents registered with the Commission.

593 *See* 17 CFR 248.10.

594 *See* 17 CFR 248.11.

include specific provisions for how covered institutions were to satisfy their obligations to safeguard customer records and information when utilizing service providers.

Covered institutions that hold transactional accounts for consumers may also be subject to Regulation S-ID.[595] Such entities must develop and implement a written identity theft program that includes policies and procedures to identify relevant types of identity theft red flags, detect the occurrence of those red flags, and respond appropriately to the detected red flags.[596]

In addition, broker-dealers that operate alternative trading systems exceeding specified volume thresholds are SCI entities subject to Regulation SCI and required, among other things, to have certain policies and procedures reasonably designed to ensure that their market systems have adequate levels of capacity, integrity, resiliency, availability, and security and take appropriate corrective action when "SCI events" occur.[597] SCI entities are required to disseminate information to their members or participants about certain types of SCI events.[598] Upon the SCI entity having a reasonable basis to conclude that a certain type of SCI event (such as a "systems intrusion" that is not de minimis) has occurred, it is generally required to promptly

---

595 Regulation S-ID applies to "financial institutions" or "creditors" that offer or maintain "covered accounts." Entities that are likely to qualify as financial institutions or creditors and maintain covered accounts include most registered brokers, dealers, funding portals, investment companies, and some registered investment advisers. *See* 17 CFR 248.201; *see also* Identity Theft Red Flag Rules, Investment Advisers Act Release No. 3582 (Apr. 10, 2013) [78 FR 23637 (Apr. 19, 2013)] ("Identity Theft Release"); *see also* 17 CFR 227.403(b).

596 In a 2017 Risk Alert, the SEC Office of Compliance Inspections and Examinations (now called the Division of Examinations) noted that, based on observations from examinations of 75 registrants, nearly all examined broker-dealers and most of the examined advisers had specific cybersecurity and Regulation S-ID policies and procedures. *See* EXAMS RISK REPORT, OBSERVATIONS FROM CYBERSECURITY EXAMINATIONS (Aug. 7, 2017), *available at* https://www.sec.gov/files/observations-from-cybersecurity-examinations.pdf; *see also* Identity Theft Release. In addition, affected entities must also periodically update their identity theft programs. *See* 17 CFR 248.201. Other rules also require updates to policies and procedures at regular intervals: s*ee*, *e.g.*, Rule 38a-1 under the Investment Company Act; FINRA Rule 3120 (Supervisory Control System); and FINRA Rule 3130 (Annual Certification of Compliance and Supervisory Processes).

597 Regulation SCI is codified at 17 CFR 242.1000 through 1007.

598 17 CFR 242.1002(c).

disseminate information about the SCI event to those members and participants that the SCI entity has reasonably estimated may have been affected. If such "SCI event" is "major," the information disseminated must be to all of the entity's members or participants.[599] When required, the notification must include a summary description of the systems intrusion, including a description of the corrective action taken by the SCI entity and when the systems intrusion has been or is expected to be resolved, unless the SCI entity determines that dissemination of such information would likely compromise the security of the SCI entity's SCI systems or indirect SCI systems, or an investigation of the systems intrusion, and documents the reasons for such determination.[600] Therefore, information about an "SCI event" caused by a cybersecurity incident may be required to be disseminated to some or all an SCI entity's members or participants pursuant to Regulation SCI.

The safeguards rule of Regulation S-P did not, before this adoption, apply to transfer agents. In addition, the disposal rule did not apply to transfer agents registered with a regulatory agency other than the Commission.[601] Thus, for these institutions, the final amendments create new requirements to adopt written policies and procedures that address administrative, technical, and physical safeguards for the protection of customer information and to take reasonable measures to protect against unauthorized access to or use of consumer information and customer information in connection with its disposal.[602] Some transfer agents registered with a regulatory agency other than the Commission may already be subject to some of the Federal regulation described below. In addition, many states impose requirements regarding the safeguarding and

---

599 17 CFR 242.1002(c)(3).

600 17 CFR 242.1002(c).

601 *See supra* section II.B.2.

602 *See* final rule 240.30(a)(1) and 240.30(b).

the disposal of customer information.[603] Hence, many transfer agents are likely to already have policies and procedures in the areas covered by these new requirements.

Some covered institutions may also be subject to other regulators' rules and guidelines implicating customer information safeguards. Transfer agents supervised by one of the Banking Agencies may be subject to the Banking Agencies' Incident Response Guidance and to the Banking Agencies' Safeguards Guidance, for example.[604] The Banking Agencies' Incident Response Guidance requires covered financial institutions to develop a response program covering assessment, notification to relevant regulators and law enforcement, incident

---

603 Twenty states have customer information safeguard requirements, and 30 states have customer information disposal requirements. *See, e.g.*, Cal. Civ. Code § 1798.81.5 ("A business that owns, licenses, or maintains personal information about a California resident shall implement and maintain reasonable security procedures and practices appropriate to the nature of the information, to protect the personal information from unauthorized access, destruction, use, modification, or disclosure."); Del. Code Tit. 6 § 12B-100 ("Any person who conducts business in this State and owns, licenses, or maintains personal information shall implement and maintain reasonable procedures and practices to prevent the unauthorized acquisition, use, modification, disclosure, or destruction of personal information collected or maintained in the regular course of business."); Fla. Stat. § 501.171(2) ("Each covered entity, governmental entity, or third-party agent shall take reasonable measures to protect and secure data in electronic form containing personal information."). *See also, e.g.*, Cal. Civ. Code § 1798.81 ("A business shall take all reasonable steps to dispose, or arrange for the disposal, of customer records within its custody or control containing personal information when the records are no longer to be retained by the business by (a) shredding, (b) erasing, or (c) otherwise modifying the personal information in those records to make it unreadable or undecipherable through any means."); La. Rev. Stat. § 51:3074(B) ("Any person that conducts business in the state or that owns or licenses computerized data that includes personal information, or any agency that owns or licenses computerized data that includes personal information shall take all reasonable steps to destroy or arrange for the destruction of the records within its custody or control containing personal information that is no longer to be retained by the person or business by shredding, erasing, or otherwise modifying the personal information in the records to make it unreadable or undecipherable through any means."); N.J. Stat. § 56:8-162 ("A business or public entity shall destroy, or arrange for the destruction of, a customer's records within its custody or control containing personal information, which is no longer to be retained by the business or public entity, by shredding, erasing, or otherwise modifying the personal information in those records to make it unreadable, undecipherable or nonreconstructable through generally available means.").

604 *See* Banking Agencies' Incident Response Guidance and Banking Agencies' Safeguards Guidance; *see also* Computershare Comment Letter ("Many registered transfer agents like Computershare US and Computershare Canada entities are banks or trust companies, and therefore already subject to state, federal, or provincial banking laws, rules, regulations and inter-agency guidelines." The commenter also refers to "Title V, Subtitle A, of the Gramm–Leach–Bliley Act, 15 U.S.C. 6801–6809; 12 CFR 30, Appendix B to Part 30 - Interagency Guidelines Establishing Information Security Standards; and New York State Department of Financial Services Cybersecurity Regulation, 23 NYCRR Part 500.").

containment, and customer notice.[605] These guidelines require customer notification if a financial institution determines that misuse of sensitive customer information "has occurred or is reasonably possible."[606] They also require notices to occur "as soon as possible," but permit delays if "an appropriate law enforcement agency determines that notification will interfere with a criminal investigation and provides the institution with a written request for the delay."[607] Under the guidelines, "sensitive customer information" means "a customer's name, address, or telephone number, in conjunction with the customer's Social Security number, driver's license number, account number, credit or debit card number, or a personal identification number or password that would permit access to the customer's account."[608] In addition, "any combination of components of customer information that would allow someone to log onto or access the customer's account, such as user name and password or password and account number" is also considered sensitive customer information under the guidelines.[609] The Banking Agencies' Safeguards Guidance directs every financial institution covered by the guidelines to require its service providers by contract to implement appropriate measures designed to protect against unauthorized access to or use of customer information that could result in substantial harm or inconvenience to any customer.[610] In addition, the Banking Agencies' Incident Response Guidance directs that an institution's contract with its service provider should require the service provider to take appropriate actions to address incidents of unauthorized access to the financial

---

605 *See* Banking Agencies' Incident Response Guidance at Supplement A, section II.A.

606 *See id.*, at Supplement A, section III.A.

607 *See id.*, at Supplement A, section III.A.

608 *See id.*, at Supplement A, section III.A.1.

609 *See id.*, at Supplement A, section III.A.1.

610 *See id.*, at Supplement A, section I.C.